

Evaluación de Seguridad Web

burmancoffee.com

Sitio evaluado: <https://burmancoffee.com>

Tipo de evaluación: Pasiva / no intrusiva (sin interrupción del servicio)

Fecha: 3 de agosto de 2026

Clasificación: Confidencial — uso interno

1. Resumen ejecutivo

Se realizó una evaluación de seguridad del sitio web **burmancoffee.com** a partir de un escaneo externo (38 comprobaciones) complementado con análisis experto y verificación forense. El objetivo fue identificar puntos débiles, servicios expuestos y riesgos antes de que puedan ser aprovechados por un tercero.

Veredicto general: la base de seguridad del sitio es **sólida**. Está protegido por Cloudflare (firewall de aplicaciones web y CDN), usa cifrado moderno (TLS 1.3) y no presenta malware, vulnerabilidades críticas conocidas ni aparece en listas negras. **No se encontró una brecha crítica ni un acceso directo al sistema**. Sin embargo, se identificaron **9 puntos de mejora**, de los cuales **dos representan un riesgo real para el negocio** y conviene atender con prioridad.

0	4	3	2
Críticos / Altos	Riesgo Medio	Riesgo Bajo	Informativos

Los 3 asuntos que más importan al negocio

① Es posible suplantar el correo de la empresa.

La configuración anti-suplantación del correo (DMARC) está en modo “solo observar”. Un tercero puede enviar correos que aparentan venir de **@burmancoffee.com** (facturas falsas a clientes, fraude a proveedores/empleados) y llegarán a la bandeja de entrada.

② Existe un entorno de desarrollo expuesto en internet.

Se detectó **dev.burmancoffee.com** visible públicamente. Estos entornos suelen estar menos protegidos y pueden revelar la dirección real del servidor, permitiendo a un atacante **rodear el firewall de Cloudflare**.

③ Una de las claves de firma del correo es débil.

Se confirmó (criptográficamente) que una de las llaves DKIM es de 1024 bits, por debajo del estándar actual de 2048 bits.

2. Alcance y metodología

Objetivo: el sitio público burmancoffee.com y su configuración de dominio, correo y transporte (TLS).

Base del análisis: informe de la herramienta de escaneo *Web-Check* (38 comprobaciones de DNS, TLS, cabeceras HTTP, correo, puertos y reputación), enriquecido con análisis manual experto y verificación forense de las claves de firma del correo.

Naturaleza: evaluación **pasiva y no intrusiva**. Equivale a observar el sitio como lo haría un visitante o una consulta pública; **no** se explotaron vulnerabilidades, **no** se envió tráfico de ataque y **no** se interrumpió el servicio en ningún momento.

Nota de transparencia. El entorno usado para elaborar este informe no tenía salida a internet habilitada, por lo que las comprobaciones *en vivo* contra el servidor no se ejecutaron; el análisis se basa en el escaneo aportado más la revisión experta. Se entregó, además, un conjunto de **herramientas de verificación** (scripts) para confirmar cada hallazgo en vivo y para una fase posterior de pruebas activas con alcance acordado.

3. Puertos y servicios expuestos

Un “puerto abierto” es una puerta de entrada a un servidor. Cuantas menos puertas innecesarias haya abiertas hacia internet, menor es la superficie de ataque.

Puertos ABIERTOS

Puerto	Servicio	Estado	Interpretación
80	HTTP	Abierto	Web sin cifrar; redirige a HTTPS. Punto de entrada de Cloudflare.
443	HTTPS	Abierto	Web cifrada (TLS 1.3). Punto de entrada de Cloudflare. Correcto.
8080	HTTP alt.	Abierto	Puerto estándar del proxy de Cloudflare; termina en el borde de Cloudflare, no en el servidor de origen.

Puertos CERRADOS hacia internet (esto es bueno)

Los servicios sensibles **no están expuestos** directamente a internet, lo cual es correcto. Se confirmó que no respondían los siguientes puertos, entre otros:

21 FTP	22 SSH	23 Telnet	25 SMTP	110 POP3	143 IMAP
389 LDAP	587 SMTP	993 IMAPS	995 POP3S	3306 MySQL	3389 RDP
5060 SIP	5900 VNC	8000 HTTP	8888 HTTP	3000 App	161 SNMP

Conclusión de puertos: la superficie de red expuesta es **mínima y adecuada**. Las únicas puertas abiertas son las del servicio web a través de Cloudflare.

4. Resumen de hallazgos

#	Hallazgo	Severidad	Riesgo para el negocio
1	Correo suplantable (DMARC en modo solo-observación + SPF débil)	Media	Phishing/fraude a clientes y empleados en nombre de la empresa
2	Entorno de desarrollo expuesto / posible IP de origen visible	Media	Un atacante podría rodear el firewall y atacar el servidor
3	Falta la cabecera HSTS	Media	Riesgo de interceptación de la conexión en redes no confiables
4	DNSSEC no habilitado	Media	Posible redirección del dominio por manipulación de DNS
5	Clave de firma de correo (DKIM) de 1024 bits	Baja	Firma de correo por debajo del estándar actual
6	Sin archivo security.txt	Baja	Sin canal claro para reportes de seguridad responsables
7	OCSF stapling no presente	Baja	Menor rendimiento/privacidad en la validación del certificado
8	Divulgación de servidor y cabeceras obsoletas	Informativa	Higiene técnica; impacto mínimo
9	Puntuación SEO 40 (no es un asunto de seguridad)	Informativa	Visibilidad en buscadores, no seguridad

5. Detalle de los hallazgos principales

Hallazgo 1 — Correo suplantable

Media

Qué es: La política DMARC del dominio está en **p=none** (solo observa, no bloquea) y el registro SPF usa **~all** (permisivo). Juntos, no impiden que un tercero envíe correo aparentando ser de @burmancoffee.com.

Riesgo: Un atacante puede enviar facturas o comunicaciones falsas a clientes, proveedores o empleados haciéndose pasar por la empresa (phishing y fraude del tipo “Business Email Compromise”). Es el hallazgo con mayor impacto directo de negocio.

Recomendación: Endurecer DMARC por fases: de p=none a **p=quarantine** y finalmente **p=reject**, revisando los informes para no afectar el correo legítimo. Ajustar SPF a **-all** cuando esté verificado.

Hallazgo 2 — Entorno de desarrollo expuesto / posible IP de origen

Media

Qué es: Se detectaron los subdominios **dev.burmancoffee.com** y **www.dev.burmancoffee.com** públicamente visibles (vía registros de transparencia de certificados).

Riesgo: Los entornos de desarrollo suelen estar menos protegidos (sin firewall, con datos de prueba o credenciales por defecto) y pueden filtrar la dirección real del servidor. Si eso ocurre, un atacante puede **rodear por completo el firewall de Cloudflare** y atacar el servidor directo.

Recomendación: Proteger dev con inicio de sesión (Cloudflare Access) o restringirlo por IP/VPN; asegurar que pasa por Cloudflare y no revela la IP de origen; verificar que no exponga paneles, código ni copias de seguridad.

Hallazgo 3 — Falta la cabecera HSTS

Media

Qué es: El sitio no envía la cabecera **Strict-Transport-Security**, que obliga al navegador a usar siempre HTTPS.

Riesgo: En una red no confiable (Wi-Fi público), un atacante podría intentar degradar la conexión a HTTP sin cifrar e interceptar datos o sesiones.

Recomendación: Activar HSTS en Cloudflare (empezar con 6 meses y luego 1 año), verificando antes que todos los subdominios funcionan por HTTPS.

Hallazgo 4 — DNSSEC no habilitado

Media

Qué es: El dominio no está firmado con DNSSEC; las respuestas DNS no tienen verificación criptográfica.

Riesgo: Facilita ataques de manipulación de DNS que podrían redirigir la web o el correo del dominio hacia servidores maliciosos.

Recomendación: Activar DNSSEC en Cloudflare (un clic) y publicar el registro DS correspondiente en el registrador (Register.com).

Hallazgo 5 — Clave de firma de correo (DKIM) de 1024 bits

Baja

Qué es: Verificado criptográficamente: de las tres claves DKIM publicadas, dos son de 2048 bits (correcto) y una es de **1024 bits** (nivel legado).

Riesgo: Una clave de 1024 bits ofrece menor garantía de autenticidad del correo firmado con ese selector.

Recomendación: Rotar esa clave a 2048 bits o eliminar el selector si ya no se utiliza.

6. Lo que está correctamente protegido

Para dar contexto equilibrado, el sitio ya hace bien muchas cosas importantes:

- Protegido por **Cloudflare** (firewall de aplicaciones web + CDN), que ya bloqueó al escáner con un desafío de seguridad.
- Cifrado moderno **TLS 1.3** con confidencialidad hacia el futuro (forward secrecy).
- Certificado SSL válido y de confianza, vigente hasta octubre de 2026.
- Protección de correo básica presente: **SPF** y **DKIM** configurados (Google Workspace).
- **Sin malware, sin phishing** y sin coincidencias en listas negras ni feeds de amenazas.
- Sin vulnerabilidades críticas conocidas en la tecnología detectada.
- Superficie de red mínima: los servicios sensibles (SSH, RDP, bases de datos) no están expuestos.
- Dominio consolidado (registrado desde 2002) y con buenas puntuaciones de rendimiento y accesibilidad.

7. Plan de acción priorizado

Prioridad	Acción	Esfuerzo
1 · Alta	Endurecer DMARC (p=none → quarantine → reject) para frenar la suplantación de correo	Bajo
2 · Alta	Revisar y proteger dev.burmancoffee.com; confirmar que no filtra la IP de origen	Medio
3 · Media	Activar HSTS en Cloudflare	Muy bajo
4 · Media	Habilitar DNSSEC (Cloudflare + Register.com)	Bajo
5 · Baja	Rotar la clave DKIM de 1024 → 2048 bits	Bajo
6 · Baja	Publicar security.txt y retirar cabeceras obsoletas	Muy bajo

8. Conclusión y próximos pasos

El sitio burmancoffee.com parte de una **buena base de seguridad** y no presenta una brecha crítica. Los hallazgos son mayoritariamente de **endurecimiento**, pero dos de ellos —la posibilidad de **suplantar el correo de la empresa** y la **exposición del entorno de desarrollo**— conllevan riesgo real de negocio y deben priorizarse. Todas las correcciones son abordables y de esfuerzo bajo o medio.

Próximo paso recomendado: ejecutar la verificación *en vivo* con las herramientas entregadas (búsqueda de IP de origen y batería de comprobaciones) desde un entorno con acceso a internet, y planificar una fase de **pruebas activas con alcance acordado** contra un entorno de pruebas para validar la lógica de la tienda y el proceso de compra.

Documento confidencial preparado para uso interno. Los hallazgos reflejan el estado observado a la fecha del informe y deben re-verificarse tras aplicar los cambios.